Application Security

Contents

Application Security **1**
- Scope . . . 1
- Official requirements . . . 1
- Project policy . . . 1
- Checklist . . . 2
- References . . . 3
- Related . . . 3

Application Security

Scope

Threats and defences that are not identity-specific. Identity is in `../authentication-authorization/STANDARD.md`. Credentials are in `../secrets-management/STANDARD.md`.

Official requirements

Subject V.6 requires anticipating malicious behaviour — brute force against the API, session theft — implementing protections, and **documenting the threats that remain unmitigated**. The API is not expected to be unbreakable; the analysis is what is graded.

External baseline: **OWASP**, adopted formally in `brain/decisions/ADR-0009-code-quality-gates.md`:

Artifact	Role	Where
ASVS 5.0.0	the conformance target — L1 everywhere applicable, L2 for V6/V7/V8/V9/V10/V16	`../../../owasp/ASVS-CONFORMANCE.md`
Top 10	per-pull-request review checklist	`../../../owasp/TOP10-CHECKLIST.md`
API Security Top 10	per-endpoint and per-hub review checklist	`../../../owasp/API-TOP10-CHECKLIST.md`
Cheat Sheet Series	read before building a security-relevant feature	`../../../owasp/CHEATSHEETS.md`

Every line of code written in this project must be OWASP-conformant. That sentence is made checkable by those four artifacts; this standard says how we implement them.

Project policy

Input handling

- Validate every request with FluentValidation in the pipeline. An unvalidated command never reaches a handler.

- Allow-list validation, not deny-list. Reject unknown fields rather than ignoring them.
- Cap every string length and every collection size at the model level. Unbounded input is a denial-of-service vector.
- Never build SQL by string concatenation. Parameterised queries only.
- Never reflect user input into an error message without encoding it.

Transport and headers

- HTTPS only, HSTS enabled, HTTP redirected.
- Security headers on every response: `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`, `Content-Security-Policy` on any HTML surface, `X-Frame-Options: DENY`.
- CORS is an explicit allow-list from configuration. Never `*` with credentials.

Rate limiting and abuse

- Global rate limit plus tighter per-endpoint limits on credential and vote endpoints.
- Limits key on account **and** IP, because either alone is trivially bypassed.
- `429` with `Retry-After`. Log the event; do not silently drop.

Data exposure

- Responses carry only the fields the caller is entitled to. No "filter on the client".
- Never return internal ids of other users, stack traces, framework versions, or SQL in errors.
- Personal data is minimised: collect what a feature needs and nothing else.

Logging hygiene

- Never log passwords, tokens, refresh tokens, API keys, `Authorization` headers, or full request bodies of credential endpoints.
- Log security events: failed login, lockout, token reuse detection, authorisation denial, rate-limit trip. These are the events a defence question will ask about.

Dependencies

- `dotnet list package --vulnerable --include-transitive` runs in CI and fails on a known high-severity advisory.
- No library source is vendored into the repository (subject IV.1).

Threat register

The register lives at `../../../owasp/THREAT-REGISTER.md`: threat, likelihood, impact, planned mitigation, residual risk, accepted by, verified.

Rules:

- A finding from either OWASP checklist that is **not fixed** in the pull request gets a row there **before that PR merges**.
- Never delete a row. Close it by pointing at the evidence that proves the mitigation.
- Subject V.6 asks for the remaining dangers to be identified and their protections described. An accepted risk that is written down is a defensible engineering decision. An unwritten one is an oversight.

Checklist

- ☐ Every command validated before the handler
- ☐ All string and collection inputs bounded
- ☐ Security headers and HSTS present
- ☐ Rate limiting on credential and vote endpoints, keyed on account and IP

- ☐ No secret or token reachable in any log
- ☐ Vulnerable-dependency scan green in CI
- ☐ Threat register written and current
- ☐ Both OWASP checklists walked, with evidence rather than opinion per row
- ☐ Every unfixed finding carries a threat-register row

References

- OWASP ASVS 5.0.0 — vendored at `docs/owasp/upstream/asvs-5.0.0/` (CC BY-SA 4.0)
- OWASP Top 10 — https://owasp.org/www-project-top-ten/
- OWASP API Security Top 10 — https://owasp.org/API-Security/
- OWASP Cheat Sheet Series — https://cheatsheetseries.owasp.org/
- ASP.NET Core rate limiting — https://learn.microsoft.com/aspnet/core/performance/rate-limit

Related

`../authentication-authorization/STANDARD.md` · `../secrets-management/STANDARD.md` · `../../60-quality/loggin`